SmartManage AI ��� Full E2E Issues Report

SmartManage AI — Full E2E Test Campaign: Issues Report

Run ID: `SMA-QA-20261009T120012Z` · **Generated:** 2026-10-09 13:36 UTC · **Repository commit:** `1378776` on branch `claude/brave-brahmagupta-mx5ti1` (identical to `main`) · **Environment tested:** local container only (see §1.3)

> All people, companies, dates, quantities, rates and documents created by this run are **synthetic test fixtures** unless labelled as coming from the supplied workbook. No real customers, employees, subcontractors or agencies were contacted; no money moved; nothing was pushed to accounting systems.

1. Executive assessment

1.1 Release blockers observed

1. **SMA-SEC-001 — the repository is compromised.** Commit `1378776` hid an obfuscated blockchain-command-and-control loader inside `postcss.config.js` (line 10, padded far off-screen). Every `npm run dev`, `build`, `vitest` and Playwright run, and the Amplify build, loads this file. Treat as an active security incident: stop deploys from `main`, rotate secrets and investigate the contributor workstation. It did not execute in this container (the module failed to parse), but that cannot be assumed elsewhere.
2. **SMA-TEN-001 — cross-tenant data corruption.** A user from one organization can write production progress into another organization's project. Confirmed in the database with `STRICT_TENANT_RLS=true`.
3. **SMA-AUTH-001 — anonymous SUPER_ADMIN session in development mode.** Any deployment running with `NODE_ENV=development` hands a platform-admin session to anonymous callers, because the `ENABLE_DEV_SEED=false` switch is ignored. Whether the hosted dev site runs in that mode could not be verified.
4. **The core money path is broken:**
   - Owner progress cannot be entered: SOV line update returns 500 (SMA-BILL-001).
   - Duplicate pay apps permanently block final retainage (SMA-BILL-002); overbilling is accepted (SMA-BILL-003).
   - The award pushes profit into the cost budget (SMA-BUD-001).
   - Approved labor vanishes from job cost once materials are received (SMA-JC-001).
   - The contract, SOV and pay apps disagree after change orders (SMA-CO-001).
5. **The supplied estimate cannot be imported with its costs** (SMA-EST-001). The estimate screen's grand total also omits profit (SMA-EST-003).

Release recommendation: NOT READY. Fix the security issues first: SMA-SEC-001, SMA-TEN-001, SMA-AUTH-001 and SMA-AUTH-002. Critical coverage is also BLOCKED: hosted environment, cross-browser engines, attachments/object storage, live integrations and live AI. Even after these fixes, release status cannot be called green until that coverage has run.

1.2 Lifecycle endpoint reached (primary project)

The primary project went from customer through closeout. Each stage, in order:

1. CRM customer, contact and opportunity created.
2. Bid `260001` created.
3. Estimate loaded: 29 lines, $782,052.11. This used the API with an explicit mapping; the UI import cannot carry costs.
4. Alternate and proposal PDFs generated.
5. Estimate approved.
6. Award: one project, `260001`, even under concurrent double-click.
7. Contract executed.
8. Schedule with CPM verified.
9. Crew and equipment assignment, with the date-based crew assignment failing.
10. Time clock and approval.
11. Production.
12. Subcontract and sub pay app.
13. PO, receipt, invoice and match.
14. RFI and submittal.
15. Change orders.
16. **Owner billing: BLOCKED on the primary project** (SMA-BILL-001). It was tested on a separate fallback project with 3 sequential pay apps; the math matched the independent G702 calculation exactly.
17. Punch list and closeout checklist.
18. Project marked **COMPLETE**.
19. Final retainage release: **BLOCKED** (SMA-BILL-002).
20. Turnover package export: **BLOCKED**, because no object storage is available locally.

This is not an uninterrupted E2E pass. It is a stage-by-stage run with one fallback seed (`260014` FALLBACK-BILLING), clearly labelled.

1.3 Scope, environment and limitations

Hosted environment: NOT TESTED.

- `https://main.d12aeb39ons832.amplifyapp.com/` is denied by this container's network policy: proxy CONNECT 403, 3 attempts.
- The hosted backend, database, storage, auth tenant and queues could not be identified.
- Every result below comes from a **local** instance of the same commit. Local results do not prove hosted behaviour.

Local stack used for every result:

- `tsx server/index.ts` with `NODE_ENV=development`, `STRICT_TENANT_RLS=true`, `EMAIL_TRANSPORT=noop`, schedulers off.
- PostgreSQL 16.15 with the schema applied by `drizzle-kit push`. That path does not run the SQL migrations, so local RLS covers 289 of 609 tables; production RLS coverage may differ.
- Seeded with the repo's own `scripts/seed-test-company.ts`: tenants RealTest Construction and RealTest Subcontractors, 21 users, shared password supplied privately.
- Timezone UTC.
- `postcss.config.js` replaced in the working tree, **uncommitted**, by the clean `a77912a` version. User-approved, to avoid loading the malicious code.

Accounts and roles:

- `admin@realtest.com` was verified to be **ADMIN of RealTest Construction**, not Super Admin.
- Super Admin was exercised as `superadmin@realtest.com`, a seeded SUPER_ADMIN.

Browsers:

- Chromium 141 only.
- Firefox and WebKit are BLOCKED: binaries are absent and installation is prohibited in this environment.
- Phone and tablet runs are emulation, not physical devices.

Test dates: 2026-10-09, 11:59–about 14:00 UTC.

2. Coverage

Denominator: 133 executed or explicitly accounted test cases in `coverage.csv`, one latest record per test ID.

- 78 harness-debug attempts were superseded after I fixed *my* harness (wrong field names and similar). They are kept in `results.harness-debug.jsonl` and are not counted.
- Discovered features, planned cases, executed cases and code coverage are different measures and are not equated.

Status	Count
PASS	66
FAIL	44
BLOCKED	18
NOT RUN	5
NOT APPLICABLE	0
Total	**133**

Inventory (static, from repository):

- 211 frontend routes.
- 209 backend router mounts, about 3,090 endpoints.
- 64 cron jobs, 13 other schedulers, 7 pg-boss queues, 7 inbound webhooks.
- 54 feature flags, 8 user roles.
- Full inventory in `inventory.md`. Most of those endpoints were **not** exercised: coverage targets the construction lifecycle, authorization and tenant boundaries.

Module coverage (this run):

Module	PASS	FAIL	BLOCKED	NOT RUN
AI	1	1	1	0
Authentication	2	2	0	0
Authorization	9	4	0	0
Background jobs	0	0	0	1
Bids	2	3	0	0
Billing	1	0	0	0

Module	PASS	FAIL	BLOCKED	NOT RUN
CRM	1	0	0	0
Change Orders	2	1	0	0
Closeout	0	1	1	0
Concurrency	1	0	0	0
Contracts	2	0	0	0
Documents	0	0	1	0
Environment	0	0	2	0
Equipment	1	1	0	0
Estimating	7	5	0	0
Integrations	1	0	5	0
Inventory modules	0	0	0	1
Job Cost	0	2	0	0
Performance	6	0	1	0
Platform	0	1	0	0
Procurement	0	1	0	0
Production	2	1	0	0
Progress Billing	4	5	5	0
Projects	2	2	0	0
RFIs	1	0	0	0
Repository suites	1	1	0	1
Resources	0	1	0	0
Schedule	3	1	0	0
Subcontracts	1	0	0	0
Submittals	1	0	0	0
Super Admin	1	1	0	0
Tenant isolation	1	1	0	0
Time Clock	3	1	0	0
Time Entry	0	1	0	0
UI	2	6	2	2
Uploads	8	1	0	0

Roles covered by real sessions:

- SUPER_ADMIN, ADMIN, HUSTLER, MANAGER, SUPERINTENDENT, ESTIMATOR, FIELD_WORKER, VENDOR, plus anonymous.
- Cross-tenant ADMIN from a second organization.
- Office manager, sales, marketing and equipment manager are **not distinct roles** in code: the seed maps them to MANAGER or FIELD_WORKER. `docs/ACCOUNT_ROLES_RBAC.md` still describes 18 roles.

Existing repository test suites (run against `sma_qa_test`):

- `npm run check` (tsc): **exit 0**.

- `vitest run`: **exit 1**: 484 failed / 4466 passed / 55 skipped tests in 5005 total, across 498 files (116 failed files).
- About 41 of the failed files are vi.mock export mismatches, i.e. test-harness rot. The rest are value and HTTP assertions; categories are in `evidence/suites/vitest-failure-categories.json`.
- Two deterministic failures map to product defects: SMA-JOB-001 and SMA-ROUTE-001.
- CI status of `main` could not be verified from here.
- Skipped tests are not counted as passes.

3. Findings by business impact

Confirmed application or repository defects: 39

- Critical: 3
- High: 17
- Medium: 13
- Low: 6

ID	Severity	Title	Tests
SMA-SEC-001	Critical	Obfuscated blockchain-C2 remote-code loader hidden in postcss.config.js (repository compromise)	SEC-001
SMA-TEN-001	Critical	Cross-tenant write: any authenticated user from another organization can post production progress to a foreign project's scope item	TEN-002
SMA-AUTH-001	Critical (if any shared env runs NODE_ENV=development); High otherwise	/api/dev/test-login issues a SUPER_ADMIN session to anonymous callers whenever NODE_ENV=development (ENABLE_DEV_SEED is ignored)	AUTH-001
SMA-BILL-001	High	Owner SOV progress entry always fails with HTTP 500 (numeric column assigned ::text)	SOV-PROG-001, PAY-001..003 (BLOCKED), PAY-NEG-002 (BLOCKED)
SMA-BILL-002	High	Duplicate pay applications accepted for the same SOV/period and cannot be voided — permanently blocks final retainage release	PAY-NEG-001, PAY-FB-NEG-001, RET-002, RET-001 (BLOCKED)
SMA-BILL-003	High	Overbilling accepted: SOV line completed > scheduled value while UI shows 100%	PAY-FB-NEG-002
SMA-EST-001	High	Bid Tab Import drops all costs and imports header/note/total rows (incl. 'Grand Total') as $0 line items	EST-IMP-001, UI-IMP-001
SMA-EST-002	High	Partial PUT of an estimate line recomputes totalCost from the request body only (zeroes total)	EST-VER-001
SMA-EST-003	High	Estimate roll-up 'appliedTotals.grandTotal' ignores per-line overhead/profit allocations (shows $623,942.68 vs priced $782,052.11)	EST-CALC-001, UI-EST-TOTAL-001
SMA-BUD-001	High	Award seeds profit allocation into cost budget 'otherBudget' (budget = contract price, not cost)	PRJ-BUD-001

ID	Severity	Title	Tests
SMA-JC-001	High	Approved labor disappears from job cost once any cost transaction (e.g. PO receipt) exists on the project	JC-001
SMA-BID-001	High	A LOST bid can be converted into a project	BID-LOST-001
SMA-BID-002	High	Estimator can PATCH a bid to AWARDED without conversion; convert then returns 409 'already converted' (bid stranded)	BID-AWD-NEG-001
SMA-CO-001	High	Contract, SOV and project contract amount diverge after change orders (COs approved before contract execution; inconsistent contractValue semantics)	CO-003, LC-COMPLETE-001
SMA-AUTH-002	High	Logout does not invalidate the JWT; a captured cookie stays valid up to 7 days	AUTH-002
SMA-RES-001	High	Crew assignments with dates always rejected (server expects Date objects from JSON); Dispatch Board forces allowOverlap:true	RES-001
SMA-CLOSE-001	High	Project closeout dashboard returns 500 for every project (enum value 'CLOSED' not in submittal_status)	UI-SCREENS-DESKTOP, UI-SCREENS-TABLET
SMA-CLOSE-002	High	CLOSED project still accepts edits, new change orders and time entries	CLOSE-003
SMA-TIME-002	High	Concurrent clock-in requests create multiple open shifts for one worker (race)	CONC-TIME-001
SMA-FLAG-001	High	Non-admin roles cannot read feature flags, so flag-gated features (e.g. Bid Tab Import) appear disabled to estimators even when enabled	UI-IMP-001
SMA-TIME-001	Medium	Manual time entries accept 30 regular hours in a day and duplicate entries for the same day/project	TIME-004
SMA-PROD-001	Medium	Production entries accept negative quantities and over-completion without flag	PROD-002
SMA-SCH-001	Medium	Schedule task with end date before start date is accepted	SCH-003
SMA-EQ-001	Medium	Equipment hour logs: reversed meter readings accepted; missing week dates -> HTTP 500	RES-003
SMA-PROC-001	Medium	Duplicate vendor invoice numbers accepted; 3-way match flags an exact partial-receipt invoice as DISCREPANCY	PROC-001
SMA-API-001	Medium	Unknown /api routes (GET/PATCH/DELETE) return HTTP 200 with the SPA HTML	API-404-001, RET-001 (DELETE)

ID	Severity	Title	Tests
SMA-CRM-001	Medium	Customer name replaced by opportunity name (and by an org UUID on convert-to-project)	PRJ-SET-001
SMA-AUD-001	Medium	Super Admin tenant creation is not written to the audit log	SA-001
SMA-RBAC-001	Medium	VENDOR role can read full internal project records (incl. contract amount)	RBAC-READ-PROJECT
SMA-EST-004	Medium	No way to record estimate-level notes/exclusions after creation; proposal omits the row-12 exclusion	EST-NOTE-001
SMA-UI-001	Medium	Horizontal overflow on every audited screen at tablet width (933px content in 768px viewport)	UI-SCREENS-TABLET
SMA-JOB-001	Medium	Scheduled job references nonexistent column equipment.pmGeneration	VITEST shared/**tests**/drizzleColumnReferences.test.ts
SMA-ROUTE-001	Medium	GET /projects/:code/punch-list/walkthrough unreachable (shadowed by /:id)	VITEST server/**tests**/route-shadowing-guard.test.ts
SMA-DOC-001	Low	Punch-list and closeout '/export/pdf' endpoints return HTML, not PDF	PUNCH-001, CLOSE-001
SMA-CLOSE-003	Low	Turnover package export returns 500 when object storage is unconfigured; closeout items completable while readiness shows open financial items	CLOSE-001 (BLOCKED)
SMA-EST-005	Low	Duplicate alternate-group code returns 500 (unique violation) instead of 409	EST-ALT-NEG-001
SMA-AI-001	Low	Prompt-injection detector misses letter-spaced obfuscation	AI-INJ-001
SMA-RBAC-002	Low	SUPER_ADMIN denied cost ledger, estimate and proposal reads despite docs saying it bypasses the org permission system	RBAC-READ-COST-LEDGER-FINANCIAL, RBAC-READ-ESTIMATE-BID, RBAC-EXPORT-PROPOSAL-PDF
SMA-FILE-001	Low	Upload above the 5 MiB multer limit returns HTTP 500 instead of 413	FILE-NEG-006

3.1 Source-data observations (workbook — not importer behaviour)

Independent recomputation reproduces every cached total: O120 $623,942.68; P120 $782,052.0975 (shown as $782,052.10); Q120 $158,109.42; margin 20.21725%. These observations are about the workbook itself and are **not** corrected:

- **SRC-01 P23** is a literal `3` instead of the row formula. Q23 = −$38,217.00. If the row template was intended, P23 would be $44,964.71 and P120 would be $827,013.81. The intended value is unresolved.

- **SRC-02 J120/S120** sum rows 111–119 rather than 11–112. Every J value is currently 0, so there is no current-dollar effect. The range is suspect.
- **SRC-03 Q120** sums Q11:Q113 (includes the SALES TAX label row). No current effect.
- **SRC-04 A27/B27:** 5.44 yd/pad × 162 = 881.28 yd, versus B27 = 1,014 yd (6.259 yd/pad); a 7×7×2 ft pad is 3.63 yd. Requires clarification (synthetic RFI-001 raised).
- **SRC-05 A30** note "$589,826.00 / $3,640.90" (= 589,826 / 162) does not match the current pads-section price.
- **SRC-06 A48** note "$25,355.71 = $67.80/sf" versus computed rows 42–47 = $25,335.71 (a $20 difference).
- **SRC-07** Equipment-like rows 15, 38 and 45 ($33,500) are priced in Other at 0% margin. Equipment J is empty and column I is hidden. Preserved as-is; no remap.
- **SRC-08** Alternate rows 55–57 ($17,074.29 price) are inside the P11:P112 grand total. Inclusion is preserved, and the customer's acceptance is unknown.
- **SRC-09/10** Labor rows use days × $3,000 with D (header "HOURS") = 1. They were **not** converted to employee hours or wages.
- **SRC-11 A12** exclusion: "GC responsible for layout." The app has no place to carry it (SMA-EST-004).
- **SRC-12** SALES TAX, OVERHEAD & PROFIT and SUBCONTRACTOR MARK UP rows have no values.
- **SRC-13 A7** "5/19/26 bids Thursday am": 19 May 2026 is a Tuesday.

Cell-level mapping, the classification of all 110 rows (11–120), and the expected-results file are in `fixtures/estimate_reconciliation.xlsx` and `fixtures/expected_results.json`.

3.2 Static concerns (code evidence; not runtime-confirmed)

- `POST /api/auth/init` is unauthenticated. On an empty users table it creates `admin@tfrllc.com` / `admin123` (`server/workforceRoutes.ts:977`).
- TOTP 2FA exists but is never checked at password login (`server/authProfileRoutes.ts:586-713`), although docs say an org policy enforces it.
- `verifyBidOrgAccess` grants access when the caller has no organization (`server/orgFilter.ts:238`). A freshly registered ADMIN with no org might read bids by id. Not runtime-tested.
- The cost ledger passes `contractAmount` (revenue) as the project budget (`server/costLedgerRoutes.ts:263`).
- Pay-app create treats `sov.contractValue` as the original contract, while sync-totals treats it as contract-plus-COs (`server/aiaBillingRoutes.ts:340` vs `:692`).
- Twilio voice webhook and SAML callback are not CSRF-exempt (`server/csrf.ts:33-71`). The SendGrid event webhook has no signature verification and is a stub.
- `requireFeature` plan gating covers only 18 routes; 8 feature flags have no server reference.
- `loadtests/budgets.json` expects `scenarios/mutations.js`, which does not exist. The nightly load run should fail; not verified.
- Estimator self-approval of estimates is allowed (`server/estimateRoutes.ts:3310`). No segregation-of-duties requirement was found, so this is unresolved.
- Dev-mode 500 responses include stack traces and SQL (`server/index.ts:473`). Production strips them.
- Lists `/api/sov` and `/api/aia-billing/pay-applications` ignore `?projectId=` and return all of the org's records. The UI filters client-side (`client/src/components/project-tabs/SovTab.tsx:78`). This is a performance and over-fetch concern.

3.3 Environment blockers

- **AI-LIVE-001** (BLOCKED): AI known-answer, extraction accuracy, latency, tenant isolation of AI context. No ANTHROPIC/OPENAI keys; AI_ESTIMATOR flag off for tenant. Only guard unit test (AI-INJ-001) and graceful-failure (AI-AVAIL-001) executed.

- **CLOSE-001** (BLOCKED): Closeout checklist init, auto-pull, complete items, readiness, turnover package export. Checklist init (10 template items), auto-pull, add item and completing 11/11 items PASSED. Turnover package export BLOCKED by environment: POST /closeout/export -> HTTP 500 {"error":"PRIVATE_OBJECT_DIR not configured"} (object storage not available locally; should be 503). /closeout/export/pdf retur
- **DEVICE-001** (NOT RUN): Physical iOS/Android device behaviour (GPS, camera, offline). No physical devices; phone viewports emulated in Chromium only.
- **HOSTED-ALL** (BLOCKED): All hosted (Amplify) functional, role, UI and load tests. Same network-policy block; every result in this report is LOCAL ONLY and does not prove hosted behaviour.
- **HOSTED-ENV-001** (BLOCKED): Hosted development frontend reachability and environment fingerprint. Outbound CONNECT to main.d12aeb39ons832.amplifyapp.com:443 denied by this container's network policy (proxy 403, 3 attempts 11:59–12:08Z). Hosted backend/DB/storage/auth tenant/queue could not be identified; no hosted test executed. Password supplied by user privately (not stored in reports).
- **INT-ESIGN-001** (BLOCKED): Electronic signature / DocuSign. No sandbox credentials.
- **INT-QBO-001** (BLOCKED): QuickBooks Online sandbox round-trip. QBO_SANDBOX_* credentials not provided; e2e/money-accounting-sync.spec.ts auto-skips.
- **INT-SAGE-001** (BLOCKED): Sage Intacct sandbox round-trip. SAGE_INTACCT_SANDBOX_* not provided.
- **INT-SMS-001** (BLOCKED): Twilio SMS/calls. No Twilio credentials. Static concern: /api/crm/calls/twilio/webhook not CSRF-exempt (needs runtime check).
- **INT-STRIPE-001** (BLOCKED): Stripe billing/webhooks. No Stripe test keys; webhook returns 503 when unset (static).
- **LOAD-HOSTED-001** (BLOCKED): Hosted stress test. Hosted isolation unverified/unreachable; only local bounded load executed.
- **OFFLINE-001** (NOT RUN): Field workflows under offline/slow network with reconnect. Not executed in this pass (time budget); mobile sync is in mobile/ app code not exercised.
- **PAY-001** (BLOCKED): Pay application #1 (period to 2026-06-30) computed and approved. BLOCKED by SOV-PROG-001: PATCH /api/sov/:sovId/line-items/:id returns HTTP 500 (column "total_previously_completed" is numeric but expression is text, sovRoutes.ts:1203-1220). Progress cannot be entered on the primary project; UI exposes no alternative. Downstream math tested on fallback project (PA
- **PAY-002** (BLOCKED): Pay application #2 (period to 2026-07-31) computed and approved. BLOCKED by SOV-PROG-001: PATCH /api/sov/:sovId/line-items/:id returns HTTP 500 (column "total_previously_completed" is numeric but expression is text, sovRoutes.ts:1203-1220). Progress cannot be entered on the primary project; UI exposes no alternative. Downstream math tested on fallback project (PA
- **PAY-003** (BLOCKED): Pay application #3 (period to 2026-08-31) computed and approved. BLOCKED by SOV-PROG-001: PATCH /api/sov/:sovId/line-items/:id returns HTTP 500 (column "total_previously_completed" is numeric but expression is text, sovRoutes.ts:1203-1220). Progress cannot be entered on the primary project; UI exposes no alternative. Downstream math tested on fallback project (PA
- **PAY-NEG-002** (BLOCKED): Overbilling: line billed beyond 100% of scheduled value. BLOCKED: the PATCH returned 500 (SOV-PROG-001), so overbilling validation never executed; an earlier automatic PASS was a false positive and is withdrawn. Static: sovRoutes.ts:1154-1163 clamps percent/balance only. Re-tested on fallback via SOV create (PAY-FB-NEG-002).
- **RET-001** (BLOCKED): Final retainage release on fallback billing project. BLOCKED by RET-002/PAY-FB-NEG-001: FINAL release correctly refused before COMPLETE (400) and while unpaid apps exist; after paying #1-#3 the duplicate DRAFT app #4 (created by the duplicate-submission probe) cannot be voided/archived/paid, so final release is permanently refused. Gate behavior itsel
- **SCHED-JOBS-001** (NOT RUN): Scheduled jobs / queue workers under load. ENABLE_SCHEDULERS=false locally; job behaviour only evidenced by repo unit tests (SMA-JOB-001).

- **STORAGE-001** (BLOCKED): Attachment upload/download/preview, closeout turnover package, cross-tenant attachment access. Object storage (PRIVATE_OBJECT_DIR / GCS) not configured locally; uploads that persist files fail (CLOSE-001).
- **SUITE-E2E-001** (NOT RUN): Repository Playwright suite (81 specs). Not executed: requires Firefox/WebKit binaries (unavailable) and ~hours runtime; campaign used its own Chromium harness instead.
- **WEBSITE-001** (NOT RUN): Website builder, marketing, bid network, portal, safety, HR, payroll modules (beyond smoke). Not exercised in this pass beyond API inventory; see inventory.md (~3,090 endpoints). Coverage is partial by design of time budget.
- **XB-FIREFOX-001** (BLOCKED): Firefox engine UI run. Firefox binary not installed; environment instructions prohibit 'playwright install'.
- **XB-WEBKIT-001** (BLOCKED): WebKit engine UI run. WebKit binary not installed (same reason).

3.4 Missing requested capabilities

- No full-cost spreadsheet estimate import (SMA-EST-001). No estimate notes or exclusions after creation (SMA-EST-004).
- No margin-based pricing: org factors are compounding markups. Per-line profitAllocation was used to preserve source prices.
- No timesheet *submit* step and no break/meal tracking (static). No equipment downtime entity (static). No project ARCHIVED status.
- No completion gate. COMPLETE is allowed with open punch items, pending COs, unpaid invoices and draft pay apps (CLOSE-002). Whether a gate is required is unresolved.
- No user-facing API to create daily reports; they arrive only via mobile sync (static).
- No optimistic-concurrency control on edits: concurrent CO edits are last-write-wins (CONC-EDIT-001). Whether that is required is unresolved.

3.5 Optional improvements

- Show both "base bid" and "base + accepted alternates" totals on the proposal; today only subtotals print.
- Map unique-violation and multer errors to 4xx globally.
- Align RBAC docs (18 roles) with code (8 roles).
- Treat the ~41 vitest files with mock drift as test debt.

4. Detailed issues

SMA-SEC-001 — Obfuscated blockchain-C2 remote-code loader hidden in postcss.config.js (repository compromise)

Overview

- Category: Security — repository/supply chain
- Severity: **Critical**
- Priority: P0
- Module: Build tooling (postcss.config.js)
- Roles: All developers, CI, Amplify build
- Environment/version: Repository HEAD 1378776 (main + working branch), commit 1378776

Reproduction

- Tests: SEC-001
- Reproducibility: Static: 1/1; runtime load attempted once (parse failed)
- Preconditions: Checkout of main at 1378776
- Steps: 1) Open postcss.config.js; scroll right on line 10 (53,923 chars). 2) Decode string table (XOR 0xC9) — see SECURITY_INCIDENT_SMA-SEC-001.md.

Behavior

- Expected (and authority): Config contains only tailwind/autoprefixer plugin map (clean version at a77912a). Authority: repository history; any executable code in a build config is unacceptable.
- Actual: Hidden function GSkqNNyuJw$_padNcYwam queries Ethereum address 0xa322E5f3D311D3080e6f0121063e9aDC2490Ef1a via public RPCs, fetches a compressed next stage and executes it with child_process/require. Introduced by commit 1378776 (author jhanjay09, 2026-08-04) together with .gitignore entries temp_auto_push.bat/temp_interactive_push.bat.
- Business impact: Any machine or CI/Amplify builder that loads the config may execute attacker code: credential theft (GitHub, AWS/Amplify, DB, API keys), further repo tampering.

Diagnosis and fix

- Evidence: `SECURITY_INCIDENT_SMA-SEC-001.md; git show 1378776 -- postcss.config.js`
- Code references: `postcss.config.js:10; .gitignore (1378776)`
- Cause: CONFIRMED malicious insertion; compromised contributor workstation = hypothesis
- Proposed fix: Restore clean config, block merges, rotate all reachable secrets, investigate jhanjay09 account/workstation and Amplify build logs since 2026-08-04, add CI hidden-payload/line-length guard.
- Workaround tested: QA used an uncommitted local restore of the a77912a version (user-approved).
- Regression acceptance: git grep GSkqNNyuJw returns nothing on all branches; CI guard fails on lines >2,000 chars in config files; secrets rotated.

SMA-TEN-001 — Cross-tenant write: any authenticated user from another organization can post production progress to a foreign project's scope item

Overview

- Category: Security — tenant isolation
- Severity: **Critical**
- Priority: P0
- Module: Production / scope progress
- Roles: Any authenticated user
- Environment/version: local @ 1378776 (+clean postcss); STRICT_TENANT_RLS=true, commit 1378776

Reproduction

- Tests: TEN-002
- Reproducibility: 1/1 (persisted row verified in DB)
- Preconditions: User in org B; scope item id from org A
- Steps: POST /api/scope-items//progress {workDate, quantityCompleted:1} as subadmin@realtest.com (RealTest Subcontractors).

Behavior

- Expected (and authority): 403/404; no row. Authority: docs/architecture/tenant-isolation.md; prompt §6.
- Actual: 201; daily_scope_progress row created by foreign user; victim scope item completed_quantity changed 0 -> 1.00.

- Business impact: Cross-tenant data corruption of production quantities that feed billing/forecast; integrity of every tenant's field data.

Diagnosis and fix

- Evidence: `evidence/api/TEN-002.json; DB query in session log`
- Code references: `server/scopeRoutes.ts:2616-2640 (no org check); scope_items/daily_scope_progress absent from migrations/0096_enable_tenant_rls.sql and have no organization_id`
- Cause: CONFIRMED: handler loads scope item by id only; no RLS backstop on these tables
- Proposed fix: Verify scopeItem.projectId belongs to req.user org (and project membership) before insert; add org scoping/RLS for scope tables; add an org-isolation test.
- Workaround tested: None for tenants.
- Regression acceptance: Foreign-org POST returns 404; row count unchanged; isolation test in server/**tests**/org-isolation covers progress routes.

SMA-AUTH-001 — /api/dev/test-login issues a SUPER_ADMIN session to anonymous callers whenever NODE_ENV=development (ENABLE_DEV_SEED is ignored)

Overview

- Category: Security — authentication
- Severity: **Critical (if any shared env runs NODE_ENV=development); High otherwise**
- Priority: P0
- Module: Auth / dev seed
- Roles: Anonymous
- Environment/version: local NODE_ENV=development, ENABLE_DEV_SEED=false. Hosted dev NODE_ENV UNVERIFIED (blocked)., commit 1378776

Reproduction

- Tests: AUTH-001
- Reproducibility: 1/1
- Preconditions: Server started with NODE_ENV=development (npm run dev)
- Steps: POST /api/dev/test-login {"role":"SUPER_ADMIN"} with no cookies; GET /api/auth/me.

Behavior

- Expected (and authority): Endpoint disabled unless explicitly enabled (ENABLE_DEV_SEED documented in .env.example as the switch).
- Actual: 200 and an auth_token for test-super_admin@dev.test (SUPER_ADMIN). Login page also renders DEV ONLY role buttons.
- Business impact: Full platform takeover of any shared dev/staging deployment running in development mode, incl. tenant data.

Diagnosis and fix

- Evidence: `evidence/api/AUTH-001.json`
- Code references: `server/utils/devSeedFlag.ts:4; server/authProfileRoutes.ts:813; server/csrf.ts dev exemption; client/src/pages/login.tsx:240-260`
- Cause: CONFIRMED gate checks only NODE_ENV
- Proposed fix: Require ENABLE_DEV_SEED=true AND non-production AND loopback/allow-listed origin; never expose SUPER_ADMIN via this route; verify hosted Amplify/backend NODE_ENV.
- Workaround tested: Ensure every shared environment runs NODE_ENV=production.

- Regression acceptance: With ENABLE_DEV_SEED unset, /api/dev/* returns 404 in all modes.

SMA-BILL-001 — Owner SOV progress entry always fails with HTTP 500 (numeric column assigned ::text)

Overview

- Category: Functional — financial (billing)
- Severity: **High**
- Priority: P1
- Module: Progress billing / SOV
- Roles: ADMIN, MANAGER
- Environment/version: local, commit 1378776

Reproduction

- Tests: SOV-PROG-001, PAY-001..003 (BLOCKED), PAY-NEG-002 (BLOCKED)
- Reproducibility: 7/7
- Preconditions: DRAFT SOV with lines
- Steps: PATCH /api/sov//line-items/ {thisPeriodCompleted:'58463'}

Behavior

- Expected (and authority): 200; line and SOV totals updated (only API to enter period progress).
- Actual: 500: column "total_previously_completed" is of type numeric but expression is of type text (stack trace in dev response).
- Business impact: Primary project cannot be billed; pay apps on primary are $0. No UI path exists either (client has no progress-entry call).

Diagnosis and fix

- Evidence: `evidence/api/PAY-001.json, evidence/api/PAY-002.json, evidence/api/PAY-003.json`
- Code references: `server/sovRoutes.ts:1203-1220; shared/schema/features/financial.ts:44 (numeric)`
- Cause: CONFIRMED schema/SQL type drift
- Proposed fix: Remove ::text casts (or cast to numeric); add integration test that PATCHes a line; add UI for period progress.
- Workaround tested: Fallback used by QA: create a new period SOV with embedded progress (POST /api/sov lineItems[].thisPeriodCompleted).
- Regression acceptance: PATCH returns 200; SOV totals equal Σ lines; pay app created from it matches independent G702.

SMA-BILL-002 — Duplicate pay applications accepted for the same SOV/period and cannot be voided — permanently blocks final retainage release

Overview

- Category: Functional — financial integrity
- Severity: **High**
- Priority: P1
- Module: Progress billing / retainage
- Roles: ADMIN, MANAGER
- Environment/version: local, commit 1378776

Reproduction

- Tests: PAY-NEG-001, PAY-FB-NEG-001, RET-002, RET-001 (BLOCKED)
- Reproducibility: 3/3
- Preconditions: Approved app on SOV
- Steps: POST /api/aia-billing/pay-applications {projectId, sovId:} twice; try status ARCHIVED/REJECTED/VOID/DELETE; pay 0.01; request FINAL retention release.

Behavior

- Expected (and authority): Duplicate rejected (prompt §5 duplicate submission); erroneous app voidable.
- Actual: Duplicate created (#4, due $0.00). No transition/DELETE route voids it (DELETE returns SPA 200), payment rejected (no balance), FINAL release refused forever: 'requires all pay applications to be paid or archived'.
- Business impact: A double-click or retry permanently prevents retainage release (cash) on the project.

Diagnosis and fix

- Evidence: `evidence/api/PAY-FB-NEG-001.json, RET-002.json, RET-001.json`
- Code references: `server/aiaBillingRoutes.ts:293-400 (no uniqueness), :200 status map, :1476 final-release gate`
- Cause: CONFIRMED
- Proposed fix: Unique (sovId) / open-draft guard + idempotency key; add VOID status with audit.
- Workaround tested: None found via API.
- Regression acceptance: Second create -> 409; VOID path exists; final release succeeds when all non-void apps paid.

SMA-BILL-003 — Overbilling accepted: SOV line completed > scheduled value while UI shows 100%

Overview

- Category: Functional — financial integrity
- Severity: **High**
- Priority: P1
- Module: Progress billing / SOV
- Roles: ADMIN, MANAGER
- Environment/version: local, commit 1378776

Reproduction

- Tests: PAY-FB-NEG-002
- Reproducibility: 1/1
- Preconditions: —
- Steps: POST /api/sov with line scheduledValue 58463, previouslyCompleted 58463, thisPeriodCompleted 10000

Behavior

- Expected (and authority): Rejected or capped (prompt §5 attempted overbilling); sub pay apps already enforce this (subcontractManagementRoutes.ts:566).
- Actual: 201; totalCompletedToDate 68,463 > 58,463; percentComplete shown 100.00; balance 0.
- Business impact: Owner invoices can exceed contract line values undetected.

Diagnosis and fix

- Evidence: `evidence/api/PAY-FB-NEG-002.json`
- Code references: `server/sovRoutes.ts:1154-1163 (clamps % only); create path`
- Cause: CONFIRMED
- Proposed fix: Validate previous+this+stored <= scheduledValue (+approved COs) server-side.
- Workaround tested: Manual review
- Regression acceptance: Over-limit request -> 400 with line detail.

SMA-EST-001 — Bid Tab Import drops all costs and imports header/note/total rows (incl. 'Grand Total') as $0 line items

Overview

- Category: Functional — estimating import (missing capability + defect)
- Severity: **High**
- Priority: P1
- Module: Estimating / import
- Roles: ESTIMATOR
- Environment/version: local (parser executed in Node + browser UI), commit 1378776

Reproduction

- Tests: EST-IMP-001, UI-IMP-001
- Reproducibility: 2/2
- Preconditions: Original 00420 workbook
- Steps: Bid estimate -> Import bid tab -> select workbook -> Import.

Behavior

- Expected (and authority): 29 priced work items with labor/material/equipment/sub/other costs; header/note/total rows excluded or flagged; total $782,052.10.
- Actual: 46 lines at $0.00 incl. company name, job #, date, 'WORK ITEMS', 7 notes, SALES TAX, OVERHEAD & PROFIT, SUBCONTRACTOR MARK UP, Grand Total; quantities default to 1.
- Business impact: Contractors' native estimates cannot be imported; silently creates misleading $0 estimate with total rows as scope.

Diagnosis and fix

- Evidence: `estimate/bidtab_parser_output.json; evidence/api/EST-IMP-001.json; evidence/screenshots/UI-IMP-001-preview.png`
- Code references: `client/src/lib/bidTabParser.ts:53-110; client/src/components/estimate/BidTabImportDialog.tsx:407-434`
- Cause: CONFIRMED by design (quantity-only parser) + no total/keyword filter
- Proposed fix: Add cost-column mapping step; skip/flag rows without quantity/unit or matching total/notes keywords; preview totals vs source footer.
- Workaround tested: Bulk API with external mapping (qa/harness/estimate-map.mjs).
- Regression acceptance: Importing 00420 yields 29 items, category totals equal F/H/J/L/N120.

SMA-EST-002 — Partial PUT of an estimate line recomputes totalCost from the request body only (zeroes total)

Overview

- Category: Functional — data integrity
- Severity: **High**
- Priority: P1
- Module: Estimating
- Roles: ADMIN, MANAGER, ESTIMATOR
- Environment/version: local, commit 1378776

Reproduction

- Tests: EST-VER-001
- Reproducibility: 3/3
- Preconditions: Line with material 1,700 + profit 728.57
- Steps: PUT /api/estimates//line-items/ {notes:'x'}

Behavior

- Expected (and authority): Only notes change; totalCost stays 2,428.57.
- Actual: totalCost persisted 0.00 while materialCost 1,700 and profitAllocation 728.57 remain; estimate total drops by 2,428.57.
- Business impact: Silent estimate/proposal/contract understatement from any partial client update.

Diagnosis and fix

- Evidence: `evidence/api/EST-VER-001.json`
- Code references: `server/estimateRoutes.ts:2231-2239`
- Cause: CONFIRMED
- Proposed fix: Merge existing row before computing totalCost (or reject partial bodies; add PATCH).
- Workaround tested: Always send full row (QA restore EST-VER-RESTORE).
- Regression acceptance: Notes-only update leaves totalCost unchanged; test added.

SMA-EST-003 — Estimate roll-up 'appliedTotals.grandTotal' ignores per-line overhead/profit allocations (shows $623,942.68 vs priced $782,052.11)

Overview

- Category: Functional — financial calculation
- Severity: **High**
- Priority: P1
- Module: Estimating
- Roles: Estimators/managers
- Environment/version: local, commit 1378776

Reproduction

- Tests: EST-CALC-001, UI-EST-TOTAL-001
- Reproducibility: 2/2 (API)
- Preconditions: Lines with profitAllocation
- Steps: GET /api/bids//estimate

Behavior

- Expected (and authority): Grand total consistent with priced lines and proposal (782,052.11) — authority: same response's totals.totalCost and proposal PDF.

- Actual: appliedTotals.grandTotal = 623,942.68 (direct cost only, org factors 0) while totals.totalCost = 782,052.11; two different 'totals' in one response. On screen (evidence/screenshots/desktop-bid-estimate-estimator.png) the estimator sees three figures at once: 'Total Estimate $782,052.11', 'Org Markup Breakdown — Grand Total $623,942.68', and 'Profit Margin $102,950.54 (15% of cost + overhead)' — none of which is the estimate's actual profit of $158,109.43. Floating action buttons overlap the Grand Total value at 1440x900.
- Business impact: Users can see a price $158,109.43 lower than the proposal; margin applied twice or dropped depending on screen.

Diagnosis and fix

- Evidence: `evidence/api/EST-CALC-001.json; evidence/screenshots/desktop-bid-estimate-estimator.png; evidence/api/UI-EST-TOTAL-001.json`
- Code references: `server/estimateRoutes.ts:606-616; server/services/aiEstimator/orgFactorsApply.ts:97`
- Cause: CONFIRMED (only 5 cost buckets passed to applyOrgFactors)
- Proposed fix: Include overhead/profit allocations, or forbid mixing per-line profit with org factors and label clearly.
- Workaround tested: Use proposal/rollup-by-line-type totals.
- Regression acceptance: grandTotal = Σ totalCost when org factors are zero.

SMA-BUD-001 — Award seeds profit allocation into cost budget 'otherBudget' (budget = contract price, not cost)

Overview

- Category: Functional — job cost
- Severity: **High**
- Priority: P1
- Module: Award / budget
- Roles: ADMIN, MANAGER
- Environment/version: local, commit 1378776

Reproduction

- Tests: PRJ-BUD-001
- Reproducibility: 1/1
- Preconditions: Estimate with profitAllocation
- Steps: POST /api/bids/`/convert; GET budget-lines`

Behavior

- Expected (and authority): Budget categories = source cost: labor 151,800; material 281,329.68; sub 98,850; other 91,963; total 623,942.68 (= project.budget).
- Actual: otherBudget 250,072.43 (+158,109.43 profit); total budget 782,052.11.

- Business impact: Job-cost variance/forecast hides the entire projected profit; overruns undetectable until profit is consumed.

Diagnosis and fix

- Evidence: `evidence/api/project-260001-budget-lines.json`
- Code references: `server/bids/storage.drizzle.ts:1229-1231,1260; also costLedgerRoutes.ts:263 uses contractAmount as budget`
- Cause: CONFIRMED
- Proposed fix: Exclude overhead/profit allocations from cost budget lines.
- Workaround tested: Manual budget edit
- Regression acceptance: Σ budget lines = Σ direct cost; matches project.budget.

SMA-JC-001 — Approved labor disappears from job cost once any cost transaction (e.g. PO receipt) exists on the project

Overview

- Category: Functional — job cost
- Severity: **High**
- Priority: P1
- Module: Job cost ledger
- Roles: Managers
- Environment/version: local, commit 1378776

Reproduction

- Tests: JC-001
- Reproducibility: 2/2 reads
- Preconditions: PO receipt posted (cost_transactions row)
- Steps: Set worker rate $45; approve 8h on cost code 01-001; GET cost-ledger

Behavior

- Expected (and authority): actualLabor +$360
- Actual: actualLabor 0 (ledger switched to 'unified engine' which never receives time-entry postings).
- Business impact: Labor actuals vanish from job-cost reports on any project that has received materials.

Diagnosis and fix

- Evidence: `evidence/api/JC-001.json`
- Code references: `server/costLedgerService.ts:105-108,164-210`
- Cause: CONFIRMED
- Proposed fix: Post approved labor to cost_transactions, or always include time entries.
- Workaround tested: None
- Regression acceptance: Approved labor appears in ledger regardless of other transactions.

SMA-BID-001 — A LOST bid can be converted into a project

Overview

- Category: Functional — workflow state
- Severity: **High**
- Priority: P1
- Module: Bids / award
- Roles: ADMIN, MANAGER
- Environment/version: local, commit 1378776

Reproduction

- Tests: BID-LOST-001
- Reproducibility: 1/1
- Preconditions: Bid SUBMITTED then LOST
- Steps: POST /api/bids/ `/convert`

Behavior

- Expected (and authority): 409/400 (LOST is terminal: bidRoutes.ts:212)
- Actual: 201 project created
- Business impact: Lost work becomes live projects/contracts/SOVs.

Diagnosis and fix

- Evidence: `evidence/api/BID-LOST-001.json`
- Code references: `server/bidRoutes.ts:697-720 (checks only AWARDED)`
- Cause: CONFIRMED

- Proposed fix: Reject convert unless status in SUBMITTED/ACTIVE (or explicit award).
- Workaround tested: Manual
- Regression acceptance: Convert LOST/CANCELLED -> 409.

SMA-BID-002 — Estimator can PATCH a bid to AWARDED without conversion; convert then returns 409 'already converted' (bid stranded)

Overview

- Category: Functional — workflow/authorization
- Severity: **High**
- Priority: P2
- Module: Bids / award
- Roles: ESTIMATOR
- Environment/version: local, commit 1378776

Reproduction

- Tests: BID-AWD-NEG-001
- Reproducibility: 1/1
- Preconditions: SUBMITTED bid
- Steps: PATCH /api/bids/ {status:'AWARDED'} as ESTIMATOR; POST convert as MANAGER

Behavior

- Expected (and authority): Award only via convert (ADMIN/MANAGER) or convert still possible.

- Actual: PATCH 200; convert 409 'This bid has already been converted to a project' with no project.
- Business impact: Awarded work cannot be set up; misleading message.

Diagnosis and fix

- Evidence: `evidence/api/BID-AWD-NEG-001.json`
- Code references: `server/bidRoutes.ts:207-214, 488-560, 708`
- Cause: CONFIRMED
- Proposed fix: Remove AWARDED from PATCH transitions; base 409 on convertedToProjectId.
- Workaround tested: None via API
- Regression acceptance: PATCH AWARDED -> 422; convert works for SUBMITTED.

SMA-CO-001 — Contract, SOV and project contract amount diverge after change orders (COs approved before contract execution; inconsistent contractValue semantics)

Overview

- Category: Functional — financial reconciliation
- Severity: **High**
- Priority: P1
- Module: Change orders / SOV / pay apps
- Roles: MANAGER
- Environment/version: local, commit 1378776

Reproduction

- Tests: CO-003, LC-COMPLETE-001
- Reproducibility: 1/1 (state)
- Preconditions: Prime contract DRAFT
- Steps: Approve +12,500 and −2,000 COs while contract DRAFT; execute contract; approve same again.

Behavior

- Expected (and authority): SOV lines = SOV.contractValue = contract = project contract = 782,052.11 + approved COs (803,052.11).
- Actual: SOV lines 803,052.11; SOV.contractValue 782,052.11; contract & project 792,552.11. Pay-app create uses contractValue+COs (803,052.11) while sync-totals treats contractValue as already including COs and roll-forward apps show 782,052.11.
- Business impact: Pay applications and contract disagree; billing limits and retainage wrong.

Diagnosis and fix

- Evidence: `evidence/api/CO-003.json; estimate/final_reconciliation.json`
- Code references: `server/changeOrderCrudRoutes.ts:569-600; server/aiaBillingRoutes.ts:336-341 vs :692-693; :1751`
- Cause: CONFIRMED divergence; root cause = propagation gated on contract status + double definitions (hypothesis for full chain)
- Proposed fix: Single source of truth for contract sum; propagate approved COs consistently or block approval until contract executed.
- Workaround tested: None
- Regression acceptance: Invariant check passes after any CO sequence.

SMA-AUTH-002
— Logout does not invalidate the JWT; a captured cookie stays valid up to 7 days

Overview

- Category: Security — session management
- Severity: **High**
- Priority: P2
- Module: Auth
- Roles: All
- Environment/version: local, commit 1378776

Reproduction

- Tests: AUTH-002
- Reproducibility: 1/1
- Preconditions: —
- Steps: Login, copy auth_token, POST /api/auth/logout, replay cookie to /api/auth/me

Behavior

- Expected (and authority): 401 (RUNBOOK_TOKEN_REVOCATION.md; prompt §6)
- Actual: 200
- Business impact: Stolen tokens survive user logout.

Diagnosis and fix

- Evidence: `evidence/api/AUTH-002.json`
- Code references: `server/authProfileRoutes.ts:716 (no tokenVersion bump/session check)`
- Cause: CONFIRMED
- Proposed fix: Check userSessions revocation in authMiddleware or bump tokenVersion on logout.
- Workaround tested: Admin revoke-tokens
- Regression acceptance: Replay after logout -> 401.

SMA-RES-001 — Crew assignments with dates always rejected (server expects Date objects from JSON); Dispatch Board forces allowOverlap:true

Overview

- Category: Functional — scheduling/resources
- Severity: **High**
- Priority: P2
- Module: Crews / dispatch
- Roles: ADMIN, MANAGER, SUPERINTENDENT
- Environment/version: local, commit 1378776

Reproduction

- Tests: RES-001
- Reproducibility: 2/2
- Preconditions: —
- Steps: POST /api/crew-assignments {crewId, projectId, startDate:'2026-06-01', endDate:'2026-09-30'} (same shape as dispatch-board.tsx:257)

Behavior

- Expected (and authority): 201; overlap with other project -> 409
- Actual: 400 'Expected date, received string'; overlap protection untestable; UI always sends allowOverlap:true.
- Business impact: Crews cannot be scheduled by date from the Dispatch Board.

Diagnosis and fix

- Evidence: `evidence/api/RES-001.json`
- Code references: `server/crewRoutes2.ts:477-496 (insertCrewProjectAssignmentSchema); client/src/pages/dispatch-board.tsx:255-260`
- Cause: CONFIRMED (z.date without coerce)
- Proposed fix: Use z.coerce.date(); stop forcing allowOverlap.
- Workaround tested: Assign without dates
- Regression acceptance: Dated assignment 201; overlapping -> 409.

SMA-CLOSE-001 — Project closeout dashboard returns 500 for every project (enum value 'CLOSED' not in submittal_status)

Overview

- Category: Functional — closeout
- Severity: **High**
- Priority: P2

- Module: Closeout
- Roles: All viewing project
- Environment/version: local (browser + API), commit 1378776

Reproduction

- Tests: UI-SCREENS-DESKTOP, UI-SCREENS-TABLET
- Reproducibility: 4/4
- Preconditions: —
- Steps: Open /projects/ (or GET /api/projects//closeout/dashboard)

Behavior

- Expected (and authority): 200
- Actual: 500 invalid input value for enum submittal_status: "CLOSED"
- Business impact: Closeout dashboard widget broken on project page.

Diagnosis and fix

- Evidence: evidence/api/UI-SCREENS-DESKTOP.json; session log
- Code references: server/closeoutRoutes.ts:1069-1070; shared/schema/enums.ts:878
- Cause: CONFIRMED
- Proposed fix: Use valid statuses (APPROVED, APPROVED_AS_NOTED).
- Workaround tested: None
- Regression acceptance: 200 for all projects.

SMA-CLOSE-002 — CLOSED project still accepts edits, new change orders and time entries

Overview

- Category: Functional — lifecycle controls
- Severity: **High**
- Priority: P2
- Module: Projects / closeout
- Roles: MANAGER, FIELD_WORKER
- Environment/version: local, commit 1378776

Reproduction

- Tests: CLOSE-003
- Reproducibility: 1/1
- Preconditions: Project COMPLETE->CLOSED
- Steps: PATCH project; POST change-order; POST time-entries

Behavior

- Expected (and authority): Rejected (CLOSED terminal per projectCrudRoutes.ts:221-243; prompt §5 post-close edit restrictions)
- Actual: 200 / 201 / 201 (clock-in was blocked)
- Business impact: Closed jobs keep accruing cost/contract changes after financial close.

Diagnosis and fix

- Evidence: `evidence/api/CLOSE-003.json`
- Code references:
  `projectOpsRoutes.ts:1263; projectFinancialRoutes.ts:134; projectCrudRoutes.ts:1116+`
- Cause: CONFIRMED (status not checked in write paths)
- Proposed fix: Central guard rejecting writes on CLOSED projects
  (with authorized reopen if required).
- Workaround tested: None
- Regression acceptance: All writes on CLOSED -> 409.

SMA-TIME-002 — Concurrent clock-in requests create multiple open shifts for one worker (race)

Overview

- Category: Functional — timekeeping/concurrency
- Severity: **High**
- Priority: P2
- Module: Time clock
- Roles: FIELD_WORKER
- Environment/version: local, commit 1378776

Reproduction

- Tests: CONC-TIME-001
- Reproducibility: 1/1 (2 of 3 parallel taps succeeded)
- Preconditions: No open shift

- Steps: Send 3 simultaneous POST /api/time-clock/clock-in

Behavior

- Expected (and authority): Exactly one shift (prompt §5 duplicate taps; route's own 'active shift' rule)
- Actual: 201, 201, 400 -> two concurrent open shifts; both later clocked out (duplicate paid time)
- Business impact: Duplicate payroll hours from double-taps / mobile retries

Diagnosis and fix

- Evidence: `evidence/api/CONC-TIME-001.json`
- Code references: `server/timeClockRoutes.ts:448 (check-then-insert, no unique constraint)`
- Cause: CONFIRMED race; fix approach hypothesis
- Proposed fix: Partial unique index on (user_id) where clock_out is null, or SELECT ... FOR UPDATE / idempotency key
- Workaround tested: Supervisor review
- Regression acceptance: Parallel taps -> one 201, rest 409; DB constraint present

SMA-FLAG-001 — Non-admin roles cannot read feature flags, so flag-gated features (e.g. Bid Tab Import) appear disabled to estimators even when enabled

Overview

- Category: Functional — authorization/feature gating
- Severity: **High**

- Priority: P2
- Module: Feature flags / Estimating UI
- Roles: ESTIMATOR, MANAGER, SUPERINTENDENT, FIELD_WORKER, VENDOR
- Environment/version: local (API + browser), commit 1378776

Reproduction

- Tests: UI-IMP-001
- Reproducibility: 2/2
- Preconditions: DOT_PAY_ITEMS enabled for org by SUPER_ADMIN (PATCH /api/feature-flags/:orgId -> 200)
- Steps: Login as estimator; open /bids//estimate; GET /api/feature-flags

Behavior

- Expected (and authority): Enabled features usable by the roles they are meant for
- Actual: GET /api/feature-flags -> 403 for ESTIMATOR; client isEnabled() false; 'Import bid tab' button disabled. ADMIN sees flag true.
- Business impact: Estimators cannot use bid-tab import (and other flag-gated UI) at all

Diagnosis and fix

- Evidence: evidence/api/CONFIG-flag-DOT_PAY_ITEMS.json; evidence/screenshots
- Code references: server/featureFlagRoutes.ts:9; client/src/hooks/use-feature-flags.ts:13; BidTabImportDialog.tsx:234-235
- Cause: CONFIRMED
- Proposed fix: Expose read-only effective flags to all org users

- Workaround tested: Admin performs imports
- Regression acceptance: Estimator sees enabled flags; import button enabled

SMA-TIME-001 — Manual time entries accept 30 regular hours in a day and duplicate entries for the same day/project

Overview

- Category: Functional — timekeeping
- Severity: **Medium**
- Priority: P2
- Module: Time entry
- Roles: FIELD_WORKER
- Environment/version: local, commit 1378776

Reproduction

- Tests: TIME-004
- Reproducibility: 1/1
- Preconditions: —
- Steps: POST /api/time-entries hoursRegular 30; POST two 8h entries same date

Behavior

- Expected (and authority): Reject >24h/day and overlapping/duplicate entries (defensible integrity; prompt §5 duplicate/overlap)

- Actual: 201, 201
- Business impact: Payroll/job cost inflation.

Diagnosis and fix

- Evidence: `evidence/api/TIME-004.json`
- Code references: `server/projectFinancialRoutes.ts:134`
- Cause: CONFIRMED
- Proposed fix: Daily cap + duplicate/overlap detection.
- Workaround tested: Supervisor review
- Regression acceptance: Both rejected with messages.

SMA-PROD-001 — Production entries accept negative quantities and over-completion without flag

Overview

- Category: Functional — production
- Severity: **Medium**
- Priority: P2
- Module: Production
- Roles: SUPERINTENDENT
- Environment/version: local, commit 1378776

Reproduction

- Tests: PROD-002

- Reproducibility: 1/1
- Preconditions: Scope 1,014 yd with 700 done
- Steps: POST progress -50; POST progress 500

Behavior

- Expected (and authority): Negative rejected; over 100% rejected or overage flagged
- Actual: 201/201; completed 1,150 > 1,014; overageActionStatus NONE
- Business impact: Corrupted percent complete, forecasts and unit-based billing.

Diagnosis and fix

- Evidence: `evidence/api/PROD-002.json`
- Code references: `server/scopeRoutes.ts:2616-2660`
- Cause: CONFIRMED
- Proposed fix: Validate quantity > 0; flag/reject overage.
- Workaround tested: —
- Regression acceptance: Negative 400; overage flagged.

SMA-SCH-001 — Schedule task with end date before start date is accepted

Overview

- Category: Functional — scheduling
- Severity: **Medium**
- Priority: P3

- Module: Schedule
- Roles: SUPERINTENDENT
- Environment/version: local, commit 1378776

Reproduction

- Tests: SCH-003
- Reproducibility: 1/1
- Preconditions: —
- Steps: POST schedule task plannedStart 2026-07-10 plannedEnd 2026-07-01

Behavior

- Expected (and authority): 400
- Actual: 201
- Business impact: Invalid CPM inputs

Diagnosis and fix

- Evidence: `evidence/api/SCH-003.json`
- Code references: `server/scheduleRoutes.ts:743`
- Cause: CONFIRMED
- Proposed fix: Validate ordering
- Workaround tested: —
- Regression acceptance: 400

SMA-EQ-001 — Equipment hour logs: reversed meter readings accepted; missing week

dates -> HTTP 500

Overview

- Category: Functional — equipment
- Severity: **Medium**
- Priority: P3
- Module: Equipment
- Roles: ADMIN
- Environment/version: local, commit 1378776

Reproduction

- Tests: RES-003
- Reproducibility: 2/2
- Preconditions: —
- Steps: POST /api/equipment//hour-logs ending<starting; and without weekStartDate

Behavior

- Expected (and authority): 400 for both
- Actual: 201 for reversed hours; 500 'null value in column week_start_date' when omitted
- Business impact: Negative usage, broken cost allocation

Diagnosis and fix

- Evidence: `evidence/api/RES-003.json`

- Code references: `server/equipmentRoutes.ts:3643`
- Cause: CONFIRMED
- Proposed fix: Zod validation of required dates and ending>=starting
- Workaround tested: —
- Regression acceptance: 400s

SMA-PROC-001 — Duplicate vendor invoice numbers accepted; 3-way match flags an exact partial-receipt invoice as DISCREPANCY

Overview

- Category: Functional — procurement
- Severity: **Medium**
- Priority: P2
- Module: Procurement
- Roles: MANAGER
- Environment/version: local, commit 1378776

Reproduction

- Tests: PROC-001
- Reproducibility: 1/1
- Preconditions: PO 26,671.68; receipt 50%
- Steps: POST invoice INV-x twice; match invoice 13,335.84

Behavior

- Expected (and authority): Duplicate rejected; match MATCHED for received qty x price
- Actual: Duplicate 201; matchStatus DISCREPANCY (receivedQtyMatchPct 50, compares to full PO)
- Business impact: Duplicate payments risk; false discrepancies block payment

Diagnosis and fix

- Evidence: `evidence/api/PROC-001.json`
- Code references: `server/procurementModuleRoutes.ts:2091 (computeThreeWayMatch)`
- Cause: CONFIRMED duplicate; match logic = hypothesis (partial receipts compared to PO total)
- Proposed fix: Unique (vendor, invoiceNumber); match against received value
- Workaround tested: Manual resolve
- Regression acceptance: Dup 409; partial match MATCHED

SMA-API-001 — Unknown /api routes (GET/PATCH/DELETE) return HTTP 200 with the SPA HTML

Overview

- Category: Functional — API contract
- Severity: **Medium**
- Priority: P2
- Module: Platform
- Roles: All API clients
- Environment/version: local dev; production statically (server/vite.ts:88-89), commit 1378776

Reproduction

- Tests: API-404-001, RET-001 (DELETE)
- Reproducibility: 5/5
- Preconditions: —
- Steps: DELETE /api/aia-billing/pay-applications/

Behavior

- Expected (and authority): 404 JSON
- Actual: 200 text/html; nothing deleted
- Business impact: Clients/integrations believe destructive or update calls succeeded

Diagnosis and fix

- Evidence: `evidence/api/API-404-001.json; RET-001.json`
- Code references: `server/vite.ts:50,88-89`
- Cause: CONFIRMED
- Proposed fix: app.use('/api', 404 JSON) before SPA fallback
- Workaround tested: —
- Regression acceptance: Unknown /api -> 404 JSON

SMA-CRM-001 — Customer name replaced by opportunity name (and by an org UUID on convert-to-project)

Overview

- Category: Functional — data mapping
- Severity: **Medium**
- Priority: P3
- Module: CRM -> bid -> project
- Roles: Sales/Managers
- Environment/version: local, commit 1378776

Reproduction

- Tests: PRJ-SET-001
- Reproducibility: 1/1
- Preconditions: Opportunity linked to CRM org
- Steps: POST /api/crm/opportunities//create-bid; convert

Behavior

- Expected (and authority): clientName = customer organisation
- Actual: clientName = opportunity name; contract parties same
- Business impact: Wrong customer on contracts, invoices, proposals

Diagnosis and fix

- Evidence: `evidence/api/project-260001-snapshot.json`
- Code references: `server/crmRoutes.ts:3038, 2982`
- Cause: CONFIRMED
- Proposed fix: Resolve organisation name

- Workaround tested: Edit bid
- Regression acceptance: clientName equals CRM org name

SMA-AUD-001 — Super Admin tenant creation is not written to the audit log

Overview

- Category: Security — auditability
- Severity: **Medium**
- Priority: P2
- Module: Platform admin
- Roles: SUPER_ADMIN
- Environment/version: local, commit 1378776

Reproduction

- Tests: SA-001
- Reproducibility: 1/1
- Preconditions: —
- Steps: POST /api/platform/organizations; query audit_log

Behavior

- Expected (and authority): Audit row (prompt §6 'privileged actions are logged')
- Actual: No row (impersonation IS audited — SA-002)
- Business impact: Untraceable tenant provisioning

Diagnosis and fix

- Evidence: `evidence/api/SA-001.json`
- Code references: `server/platformRoutes.ts:288-319`
- Cause: CONFIRMED
- Proposed fix: Add auditLogger call
- Workaround tested: —
- Regression acceptance: Audit row with actor/org id

SMA-RBAC-001 — VENDOR role can read full internal project records (incl. contract amount)

Overview

- Category: Security — authorization
- Severity: **Medium**
- Priority: P2
- Module: Projects
- Roles: VENDOR
- Environment/version: local, commit 1378776

Reproduction

- Tests: RBAC-READ-PROJECT
- Reproducibility: 1/1
- Preconditions: —
- Steps: GET /api/projects/260001 as vendor@realtest.com

Behavior

- Expected (and authority): Denied (rbac-audit.md: VENDOR 'No contractor features')
- Actual: 200 with full project JSON
- Business impact: Commercial data exposure to external vendors in the tenant

Diagnosis and fix

- Evidence: `evidence/api/RBAC-READ-PROJECT.json`
- Code references: `server/projectCrudRoutes.ts (GET /api/projects/:code)`
- Cause: CONFIRMED
- Proposed fix: Deny VENDOR or return portal-safe projection
- Workaround tested: —
- Regression acceptance: VENDOR 403

SMA-EST-004 — No way to record estimate-level notes/exclusions after creation; proposal omits the row-12 exclusion

Overview

- Category: Missing capability
- Severity: **Medium**
- Priority: P3
- Module: Estimating / proposal
- Roles: ESTIMATOR

- Environment/version: local, commit 1378776

Reproduction

- Tests: EST-NOTE-001
- Reproducibility: 1/1
- Preconditions: —
- Steps: Try PATCH/PUT /api/estimates/

Behavior

- Expected (and authority): Notes/exclusions editable and printed (prompt §3)
- Actual: No route (SPA 200); proposal renders est.notes only
- Business impact: Exclusions (GC layout responsibility) cannot be communicated in proposals

Diagnosis and fix

- Evidence: `evidence/api/EST-NOTE-001.json`
- Code references: `server/estimatePricingRoutes.ts:713; no estimate update route`
- Cause: CONFIRMED
- Proposed fix: Add notes/exclusions editor + API
- Workaround tested: $0 line item
- Regression acceptance: Exclusion appears in proposal PDF

SMA-UI-001 — Horizontal overflow on every audited screen at tablet width (933px content in 768px viewport)

Overview

- Category: UI/responsive
- Severity: **Medium**
- Priority: P3
- Module: App shell
- Roles: All tablet users
- Environment/version: Chromium emulation, commit 1378776

Reproduction

- Tests: UI-SCREENS-TABLET
- Reproducibility: 11/11 pages
- Preconditions: —
- Steps: Open any page at 768x1024

Behavior

- Expected (and authority): No horizontal page scroll
- Actual: scrollWidth 933 > 768
- Business impact: Tablet field use impaired

Diagnosis and fix

- Evidence: `evidence/screenshots/tablet-*.png`
- Code references: `(not isolated)`
- Cause: Hypothesis: fixed-width header/sidebar at md breakpoint

- Proposed fix: Inspect TopHeader/sidebar min-widths
- Workaround tested: Landscape
- Regression acceptance: scrollWidth<=innerWidth

SMA-JOB-001 — Scheduled job references nonexistent column equipment.pmGeneration

Overview

- Category: Functional — background job (from existing test suite)
- Severity: **Medium**
- Priority: P2
- Module: Equipment PM job
- Roles: n/a
- Environment/version: vitest, commit 1378776

Reproduction

- Tests: VITEST shared/**tests**/drizzleColumnReferences.test.ts
- Reproducibility: 2/2
- Preconditions: —
- Steps: npx vitest run shared/**tests**/drizzleColumnReferences.test.ts

Behavior

- Expected (and authority): pass

- Actual: fails: equipment.pmGeneration at server/jobs/jobRunner.ts:2036
- Business impact: Preventive-maintenance job likely errors at runtime (schedulers off locally — runtime not observed)

Diagnosis and fix

- Evidence: `evidence/suites/vitest.log`
- Code references: `server/jobs/jobRunner.ts:2036`
- Cause: CONFIRMED by repo test
- Proposed fix: Fix column reference
- Workaround tested: —
- Regression acceptance: test passes

SMA-ROUTE-001 — GET /projects/:code/punch-list/walkthrough unreachable (shadowed by /:id)

Overview

- Category: Functional — routing (from existing test suite)
- Severity: **Medium**
- Priority: P3
- Module: Punch list
- Roles:
- Environment/version: vitest, commit 1378776

Reproduction

- Tests: VITEST server/**tests**/route-shadowing-guard.test.ts
- Reproducibility: 2/2
- Preconditions: —
- Steps: run test

Behavior

- Expected (and authority): pass
- Actual: fails
- Business impact: Walkthrough endpoint returns item lookup

Diagnosis and fix

- Evidence: `evidence/suites/vitest.log`
- Code references: `server/punchListRoutes.ts:223 vs :754`
- Cause: CONFIRMED
- Proposed fix: Reorder routes
- Workaround tested: —
- Regression acceptance: test passes

SMA-DOC-001 — Punch-list and closeout '/export/pdf' endpoints return HTML, not PDF

Overview

- Category: Functional — documents
- Severity: **Low**

- Priority: P3
- Module: Closeout
- Roles:
- Environment/version: local, commit 1378776

Reproduction

- Tests: PUNCH-001, CLOSE-001
- Reproducibility: 2/2
- Preconditions: —
- Steps: GET /api/projects/ /punch-list/export/pdf

Behavior

- Expected (and authority): application/pdf
- Actual: text/html
- Business impact: Downloads labeled PDF are HTML

Diagnosis and fix

- Evidence: `evidence/docs/PUNCH-001-export.html`
- Code references: `server/punchListRoutes.ts; server/closeoutRoutes.ts:1103`
- Cause: CONFIRMED
- Proposed fix: Render PDF or rename endpoint
- Workaround tested: Browser print
- Regression acceptance: %PDF

SMA-CLOSE-003
— Turnover package export returns 500 when object storage is unconfigured; closeout items completable while readiness shows open financial items

Overview

- Category: Functional — closeout
- Severity: **Low**
- Priority: P3
- Module: Closeout
- Roles:
- Environment/version: local (no object storage), commit 1378776

Reproduction

- Tests: CLOSE-001 (BLOCKED)
- Reproducibility: 1/1
- Preconditions: —
- Steps: POST /closeout/export

Behavior

- Expected (and authority): 503 with clear message; readiness informs completion
- Actual: 500 'PRIVATE_OBJECT_DIR not configured'
- Business impact: Misclassified error

Diagnosis and fix

- Evidence: `evidence/api/CLOSE-001.json`
- Code references: `server/closeoutRoutes.ts:743`
- Cause: CONFIRMED
- Proposed fix: 503; surface readiness
- Workaround tested: —
- Regression acceptance: 503

SMA-EST-005 — Duplicate alternate-group code returns 500 (unique violation) instead of 409

Overview

- Category: Functional — validation
- Severity: **Low**
- Priority: P3
- Module: Estimating
- Roles: ESTIMATOR
- Environment/version: local, commit 1378776

Reproduction

- Tests: EST-ALT-NEG-001
- Reproducibility: 3/3
- Preconditions: —
- Steps: POST alternate-groups code ALT-1 twice

Behavior

- Expected (and authority): 409
- Actual: 500 (+ stack in dev)
- Business impact:

Diagnosis and fix

- Evidence: `evidence/api/EST-ALT-NEG-001.json`
- Code references: `server/estimatePricingRoutes.ts:84`
- Cause: CONFIRMED
- Proposed fix: Map 23505 to 409
- Workaround tested: —
- Regression acceptance: 409

SMA-AI-001 — Prompt-injection detector misses letter-spaced obfuscation

Overview

- Category: Security — AI (heuristic)
- Severity: **Low**
- Priority: P3
- Module: AI guard
- Roles:
- Environment/version: unit, commit 1378776

Reproduction

- Tests: AI-INJ-001
- Reproducibility: 1/1
- Preconditions: —
- Steps: detectPromptInjection('I g n o r e a l l p r e v i o u s ...')

Behavior

- Expected (and authority): flagged
- Actual: not flagged (still quarantine-wrapped)
- Business impact: Defense-in-depth gap

Diagnosis and fix

- Evidence: `evidence/ai-guard-results.json`
- Code references: `server/ai/promptInjectionGuard.ts:61-130`
- Cause: CONFIRMED
- Proposed fix: Collapse single-char spacing in normalizeForDetection
- Workaround tested: —
- Regression acceptance: flagged

SMA-RBAC-002 — SUPER_ADMIN denied cost ledger, estimate and proposal reads despite docs saying it bypasses the org permission system

Overview

- Category: Documentation/authorization mismatch
- Severity: **Low**
- Priority: P4
- Module: Authorization
- Roles: SUPER_ADMIN
- Environment/version: local, commit 1378776

Reproduction

- Tests: RBAC-READ-COST-LEDGER-FINANCIAL, RBAC-READ-ESTIMATE-BID, RBAC-EXPORT-PROPOSAL-PDF
- Reproducibility: 3/3
- Preconditions: —
- Steps: GET as superadmin@

Behavior

- Expected (and authority): Per docs/rbac-audit.md: allow
- Actual: 403
- Business impact: Support tooling gaps; doc drift

Diagnosis and fix

- Evidence: `evidence/api/RBAC-*.json`
- Code references: `costLedgerRoutes.ts:255 canAccessCostLedger; estimateRoutes hasEstimateAccess`

- Cause: CONFIRMED
- Proposed fix: Decide intended behaviour; align docs or guards
- Workaround tested: Impersonation
- Regression acceptance: Consistent

SMA-FILE-001 — Upload above the 5 MiB multer limit returns HTTP 500 instead of 413

Overview

- Category: Functional — uploads
- Severity: **Low**
- Priority: P3
- Module: Uploads (prevailing-wage import)
- Roles: MANAGER
- Environment/version: local, commit 1378776

Reproduction

- Tests: FILE-NEG-006
- Reproducibility: 1/1
- Preconditions: —
- Steps: POST 5.25 MiB CSV to /api/labor-rates/prevailing-wage-rates/import-preview

Behavior

- Expected (and authority): 413 with size message

- Actual: 500 (MulterError LIMIT_FILE_SIZE not mapped)
- Business impact: Confusing error; noise in error tracking

Diagnosis and fix

- Evidence: `evidence/api/FILE-NEG-006.json`
- Code references: `server/laborRateRoutes.ts:52-56; server/index.ts error handler`
- Cause: CONFIRMED
- Proposed fix: Map MulterError LIMIT_FILE_SIZE -> 413 globally
- Workaround tested: —
- Regression acceptance: 413

5. Estimate → contract → billing → closeout reconciliation

Quantity	Source / independent	App	Variance
Direct cost	$623,942.68 (O120)	$623,942.68 (project.budget; appliedTotals.grandTotal)	0.00
Price incl. ALT-1	$782,052.0975 → $782,052.10 (P120)	$782,052.11 (Σ per-line cents)	+0.01 rounding policy
Base ex-alternate	$764,977.81	$764,977.82	+0.01 rounding
Budget lines total	$623,942.68	$782,052.11	+$158,109.43 (SMA-BUD-001)
Approved CO net	+$21,000.00 (4 approved incl. pre-execution pair)	$21,000.00	0
Contract after COs	$803,052.11 (782,052.11 + 21,000)	$792,552.11	-10,500.00 (SMA-CO-001)
SOV-001 Σ lines	$803,052.11	$803,052.11; SOV.contractValue $782,052.11	contractValue stale
Primary billing to date	n/a	$0 (SMA-BILL-001 blocks progress entry)	BLOCKED

Quantity	Source / independent	App	Variance
Fallback: completed & stored (3 apps)	$609,378.19	$609,378.19	0.00
Fallback: retainage held	$60,937.82	$60,937.82	0.00 (final release BLOCKED, SMA-BILL-002)
Fallback: certified & paid (fixture receipts)	$548,440.37	$548,440.37	0.00
Labor actual (8 h × $45)	$360.00	$0.00	−$360 (SMA-JC-001)
Material actual (PO receipt 50%)	$13,335.84	$13,335.84	0.00
Production R27	700 + over-entries	1,150 / 1,014 yd completed	over-complete accepted (SMA-PROD-001)

Synthetic overrides used:

- The contract amount equals the app's priced estimate ($782,052.11, including ALT-1); acceptance of the source alternate was assumed for the lifecycle only.
- Billing percentages: `fixtures/billing_expected.json`.
- Schedule durations: `fixtures/schedule_expected_cpm.json`.
- Worker cost rate: $45/h.
- Every variance is reported rather than forced to zero. Full JSON: `estimate/final_reconciliation.json`.

6. UI, authorization, integration/AI and performance

UI (Chromium 141 emulation):

- **UI-EST-TOTAL-001 FAIL** — Bid estimate screen total shown to the estimator: screen shows $782,052.11, $623,942.68

- **UI-IMP-001 FAIL** — Upload original 00420 workbook through Bid Tab Import dialog (real UI): preview total "46 rows", importable "46 will import"; Grand Total row listed: false; no cost columns in preview

- **UI-ROLE-001 PASS** — Field worker direct-URL navigation to financial screens:

- **UI-SCREENS-DESKTOP FAIL** — Key screens render as MANAGER at desktop 1440x900: project-detail 5xx: 500 GET /api/projects/260001/closeout/dashboard

- **UI-SCREENS-PHONE360 FAIL** — Key screens render as MANAGER at phone360 360x800: project-detail 5xx: 500 GET /api/projects/260001/closeout/dashboard

- **UI-SCREENS-PHONE390 FAIL** — Key screens render as MANAGER at phone390 390x844: project-detail 5xx: 500 GET /api/projects/260001/closeout/dashboard

- **UI-SCREENS-TABLET FAIL** — Key screens render as MANAGER at tablet 768x1024: dashboard horizontal overflow 933>768 | projects horizontal overflow 933>768 | project-detail horizontal overflow 933>768 | project-detail 5xx: 500 GET /api/projects/260001/closeout/dashboard | project-schedule horizontal overflow 933>768 | project-financials horizontal overflow 933>768 | bid-estimate horizontal overflow 933>768 | progress-billing horizontal overflow 933>768 | time-clock horizonta

- **UI-TIME-001 PASS** — Field worker clocks in/out on phone (390x844) with simulated geolocation:

Automated accessibility (axe-core 4.10.2, WCAG 2 A/AA; scanner results only, not a conformance claim). Top violations by node count:

Rule	Impact	Nodes
color-contrast	serious	206
button-name	critical	112
meta-viewport	critical	22
label	critical	12
aria-progressbar-name	serious	8
aria-input-field-name	serious	6
aria-valid-attr-value	critical	4
scrollable-region-focusable	serious	4

Manual keyboard and focus review was **NOT RUN**.
Screenshots are in `evidence/screenshots/`.

Authorization and tenant isolation:

- **AUTH-001 FAIL**: Anonymous access to dev login endpoint (NODE_ENV=development). Anonymous caller obtained a SUPER_ADMIN session via POST /api/dev/test-login (200) with ENABLE_DEV_SEED=false; gate depends only on NODE_ENV=development. Hosted dev NODE_ENV UNVERIFIED.
- **AUTH-002 FAIL**: Logout invalidates the session token. pre-logout token still valid after logout (/api/auth/me 200)
- **AUTH-003 PASS**: Disabled user and role change take effect on existing sessions.
- **AUTH-004 PASS**: Password reset via captured test sink.
- **RBAC-CREATE-CHANGE-ORDER PASS**: Role matrix: Create change order. {"SUPER_ADMIN":"201","ADMIN":"201","HUSTLER":"403","MANAGER":"201","SUPERINTENDENT":"201","ESTIMATOR":"403","FIELD_WORKER":"403","VENDOR":"403","ANON":"401"}
- **RBAC-CREATE-EQUIPMENT PASS**: Role matrix: Create equipment. {"SUPER_ADMIN":"201","ADMIN":"400","HUSTLER":"400","MANAGER":"400","SUPERINTENDENT":"400","ESTIMATOR":"400","FIELD_WORKER":"403","VENDOR":"403","ANON":"401"}
- **RBAC-CREATE-PAY-APPLICATION PASS**: Role matrix: Create pay application. {"SUPER_ADMIN":"404","ADMIN":"404","HUSTLER":"404","MANAGER":"404","SUPERINTENDENT":"403","ESTIMATOR":"403","FIELD_WORKER":"403","VENDOR":"403","ANON":"401"}
- **RBAC-CREATE-USER PASS**: Role matrix: Create user. {"SUPER_ADMIN":"400","ADMIN":"400","HUSTLER":"403","MANAGER":"403","SUPERINTENDENT":"403","ESTIMATOR":"403","FIELD_WORKER":"403","VENDOR":"403","ANON":"401"}
- **RBAC-EXPORT-PROPOSAL-PDF FAIL**: Role matrix: Export proposal PDF. SUPER_ADMIN expected allow got 403 | {"SUPER_ADMIN":"403","ADMIN":"200","HUSTLER":"403","MANAGER":"200","SUPERINTENDENT":"403","ESTIMATOR":"200","FIELD_WORKER":"403","VENDOR":"403","ANON":"401"}
- **RBAC-LIST-ORG-USERS PASS**: Role matrix: List org users. {"SUPER_ADMIN":"200","ADMIN":"200","HUSTLER":"200","MANAGER":"200","SUPERINTENDENT":"200","ESTIMATOR":"200","FIELD_WORKER":"403","VENDOR":"403","ANON":"401"}
- **RBAC-PLATFORM-ORG-LIST PASS**: Role matrix: Platform org list. {"SUPER_ADMIN":"200","ADMIN":"403","HUSTLER":"403","MANAGER":"403","SUPERINTENDENT":"403","ESTIMATOR":"403","FIELD_WORKER":"403","VENDOR":"403","ANON":"401"}
- **RBAC-READ-COST-LEDGER-FINANCIAL FAIL**: Role matrix: Read cost ledger (financial). SUPER_ADMIN expected allow got 403 | {"SUPER_ADMIN":"403","ADMIN":"200","HUSTLER":"200","MANAGER":"200","SUPERINTENDENT":"200","ESTIMATOR":"200","FIELD_WORKER":"403","VENDOR":"403","ANON":"401"}

- **RBAC-READ-ESTIMATE-BID FAIL**: Role matrix: Read estimate/bid. SUPER_ADMIN expected allow got 403 | {"SUPER_ADMIN":"403","ADMIN":"200","HUSTLER":"200","MANAGER":"200","SUPERINTENDENT":"200","ESTIMATOR":"200","FIELD_WORKER":"403","VENDOR":"403","ANON":"401"}

- **RBAC-READ-PAY-APP-G-FINANCIAL PASS**: Role matrix: Read pay app G702 (financial). {"SUPER_ADMIN":"200","ADMIN":"200","HUSTLER":"200","MANAGER":"200","SUPERINTENDENT":"200","ESTIMATOR":"200","FIELD_WORKER":"403","VENDOR":"403","ANON":"401"}

- **RBAC-READ-PRIME-CONTRACT-LIST PASS**: Role matrix: Read prime contract list. {"SUPER_ADMIN":"200","ADMIN":"200","HUSTLER":"403","MANAGER":"200","SUPERINTENDENT":"200","ESTIMATOR":"403","FIELD_WORKER":"403","VENDOR":"403","ANON":"401"}

- **RBAC-READ-PROJECT FAIL**: Role matrix: Read project. VENDOR expected deny got 200 | {"SUPER_ADMIN":"200","ADMIN":"200","HUSTLER":"200","MANAGER":"200","SUPERINTENDENT":"200","ESTIMATOR":"200","FIELD_WORKER":"200","VENDOR":"200","ANON":"401"}

- **RBAC-READ-SOV-LIST-FINANCIAL PASS**: Role matrix: Read SOV list (financial). {"SUPER_ADMIN":"200","ADMIN":"200","HUSTLER":"200","MANAGER":"200","SUPERINTENDENT":"200","ESTIMATOR":"200","FIELD_WORKER":"403","VENDOR":"403","ANON":"401"}

- **SA-001 FAIL**: Super Admin: create test tenant, list orgs, audit log records privileged action; impersonation audited. audit log does not show tenant creation (audit endpoint 200; 36744B)

- **SA-002 PASS**: Super Admin impersonation is restricted to SUPER_ADMIN and audited.

- **TEN-001 PASS**: Cross-tenant reads by another org's ADMIN using primary project IDs. 18 object reads + 5 lists: no foreign data returned

- **TEN-002 FAIL**: Cross-tenant writes by another org's ADMIN. CROSS-TENANT WRITE: foreign scope progress -> 201

Integrations and AI: see §3.3.

- Delivery was only verified to the in-memory email sink.

- The AI prompt-injection guard was executed directly.

- No live provider calls were made, so no model, latency or accuracy claims are made.

Performance (bounded, LOCAL ONLY):

- Harness: `qa/harness/load.mjs`, global ceiling 20 req/s, think time 1000-3000 ms.
- Mix: project read/search, schedule, scope read, production write, time-clock cycle, cost ledger, G702 PDF.
- Abort limits: >5% 5xx over 60 s, or p95 >10 s for 2 windows.

Stage	Duration s	Requests	Achieved rps	5xx/net err	4xx	p50 ms	p95 ms	p99 ms	Aborted
vu-1	60	29	0.48	0 (0.00%)	0	25	51	74	no
vu-5	122	290	2.38	0 (0.00%)	0	25	57	130	no
vu-10	122	595	4.87	0 (0.00%)	0	25	61	105	no
vu-25	123	1473	11.99	0 (0.00%)	0	27	70	362	no
soak-25	903	11053	12.25	0 (0.00%)	0	27	72	109	no

Per-operation latency for the last stage (ms):

Operation	n	p50	p95	p99	Statuses
cost_ledger_read	1104	27	57	103	{'200': 1104}
file_g702_pdf	576	31	59	98	{'200': 576}
production_write	1112	35	69	102	{'201': 1112}
project_read	2770	24	46	70	{'200': 2770}
project_search	1634	23	47	72	{'200': 1634}
schedule_read	1693	22	46	66	{'200': 1693}
scope_read	1075	24	50	70	{'200': 1075}
timeclock_cycle	1089	66	114	174	{'200': 1089}

Post-load integrity: 1347 production writes returned 201, against a persisted quantity sum of 1347 (match: True).

- These are measurements on a single local container, not a capacity statement.
- No product SLA exists for these operations. `loadtests/budgets.json` sets p95 2 s / 1% error, so **capacity acceptance criteria are not established**.
- Saturation was not claimed.

- Resource, queue and DB-pool telemetry was not collected.

7. Remediation order, open questions, residual risk, re-test

Order:

1. Security incident SMA-SEC-001: Security + DevOps.
2. Tenant isolation and auth: SMA-TEN-001, SMA-AUTH-001, SMA-AUTH-002, SMA-RBAC-001 (Backend/security). Add org-isolation tests for every `:id` route lacking org scoping, and complete RLS coverage.
3. Billing integrity: SMA-BILL-001/002/003 and SMA-CO-001 (Backend/finance).
4. Job cost and budget: SMA-BUD-001, SMA-JC-001, SMA-EST-002/003 (Backend).
5. Workflow state: SMA-BID-001/002, SMA-CLOSE-001/002, SMA-TIME-001/002, SMA-RES-001 (Backend).
6. Import capability: SMA-EST-001/004 (Frontend + Backend).
7. Remaining Medium and Low issues: SMA-UI-001 (Frontend); test-suite repair (QA/Eng).

Open questions for the product owner:

- Intended P23 value and the row-27 quantity.
- Customer acceptance of ALT-1.
- Should completion be gated on readiness?
- Segregation of duties for estimate approval.
- Is optimistic concurrency required?
- Which NODE_ENV and dependencies does the hosted Amplify dev site use?
- Should SUPER_ADMIN read tenant financials?

Residual risk: hosted behaviour, Firefox/WebKit, physical devices, attachments, integrations, AI quality, scheduled jobs and about 90% of the endpoint inventory remain untested.

Re-test: follow `qa/README.md`. Run the stage scripts in order, then the UI and load harnesses, then `python3 -I qa/report/build_report.py qa/runs/<run-id>`.

8. Records, documents and cleanup

Primary QA project, retained for review:

- Project `260001` (id `f58a8098-8b7a-4171-a93d-d9a3d56ae65b`)
- Bid `260001`, estimate `eb5babbd-ee04-4459-9a67-6fde14865374`
- Contract `ec183248-1e59-4a49-be02-bddfcaf369c7`, SOV `5902a27d-66ee-4be0-a3c9-ef2e8e86f141`

Other QA records:

- Fallback billing project `260014`
- Second-site project `260013`
- Completion-gate project `260015` (CLOSED)
- Load project `260020`
- Platform test tenant `63233184-857c-4946-8d52-29425ef7f514`
- All IDs are in `state.json`; all names start with `SMA-QA-20261009T120012Z`.

Account changes:

- `dispatcher@realtest.com` password was changed by AUTH-004 (local DB only).
- The temp PM user was deactivated by AUTH-003.
- 25 synthetic `qa-load-*` users were created for the load test.

Cleanup status:

- No records were deleted. The DELETE calls in RET-001 matched no route and changed nothing.
- Load data is retained. It is test-owned and can be removed from the manifest if wanted.
- The local database is disposable (container). Nothing touched the hosted environment.

Fixture documents: 55 files with SHA-256 in `fixtures/MANIFEST.csv`. Every synthetic PDF carries the "TEST ONLY — NOT VALID FOR BUSINESS USE" banner.

File	Purpose	Provenance	Tests
`fixtures/estimate_reconciliation.xlsx`	Cell-level mapping, row classification, independent expected results, source issues	DERIVED from source workbook	EST-, *PRJ-*
`fixtures/expected_results.json`	Independent expected estimate totals (precision + rounding)	DERIVED	EST-IMP-002, EST-CALC-001, EST-ALT-001
`fixtures/normalized_import_00420.csv`	Deterministic normalized dataset (NOT a corrected estimate) used for EST-IMP-002 bulk load	DERIVED from source (no value changes)	EST-IMP-002
`fixtures/scope_and_exclusions.pdf`	Scope and exclusions	SYNTHETIC	EST-NOTE-001, EST-PROP-*
`fixtures/alternate_schedule.pdf`	Alternate schedule	SYNTHETIC	EST-ALT-001, EST-PROP-*
`fixtures/award_notice.pdf`	Award notice	SYNTHETIC	BID-AWD-001
`fixtures/test_prime_agreement.pdf`	Test prime agreement	SYNTHETIC	CTR-EXEC-001
`fixtures/baseline_sov.xlsx`	Baseline schedule of values (= estimate line prices)	DERIVED	PRJ-SOV-001

File	Purpose	Provenance	Tests
fixtures/cost_code_mapping.csv	Cost-code mapping as seeded by award	SYNTHETIC	PRJ-BUD-001
fixtures/project_contacts.csv	Project contacts	SYNTHETIC	LC-CRM-001
fixtures/work_calendar.csv	Work calendar	SYNTHETIC	SCH-004
fixtures/task_schedule.csv	Task schedule with dependencies/milestone (independent CPM)	SYNTHETIC	SCH-001, SCH-004
fixtures/baseline_staffing.csv	Baseline staffing (synthetic)	SYNTHETIC	RES-001
fixtures/equipment_roster.csv	Equipment roster & cost rates (synthetic rates)	SYNTHETIC	RES-002, RES-003
fixtures/procurement_schedule.csv	Procurement schedule	SYNTHETIC	PROC-001
fixtures/employee_roster.csv	Employee roster & pay rules (synthetic)	SYNTHETIC	JC-001, TIME-*
fixtures/subcontractor_roster.csv	Subcontractor roster	SYNTHETIC	SUB-001
fixtures/vendor_quote.pdf	Vendor Quote — Fictional Rebar Supply Co	SYNTHETIC	PROC-001
fixtures/test_subcontract.pdf	Subcontract (fixture)	SYNTHETIC	SUB-001
fixtures/purchase_order.pdf	Purchase Order PO-0001 (fixture)	SYNTHETIC	PROC-001
fixtures/delivery_ticket.pdf	Delivery Ticket DT-QA-0001	SYNTHETIC	PROC-001
fixtures/supplier_invoice.pdf	Supplier Invoice INV-SMA-QA-20261009T120012Z-1	SYNTHETIC	PROC-001
fixtures/daily_field_report.pdf	Daily Field Report 2026-07-20	SYNTHETIC	PROD-001
fixtures/equipment_inspection_maintenance.pdf	Equipment Inspection & Maintenance	SYNTHETIC	RES-003
fixtures/safety_checklist.pdf	Safety Checklist — saw cutting	SYNTHETIC	(no API run; see coverage)
fixtures/delay_report.pdf	Delay Report	SYNTHETIC	(fixture only)
fixtures/rfi_and_response.pdf	RFI-001 & Response	SYNTHETIC	RFI-001
fixtures/submittal_and_revision.pdf	Submittal: Crackbond CSR product data	SYNTHETIC	SUBM-001
fixtures/change_request.pdf	Change Requests	SYNTHETIC	CO-001
fixtures/sub_progress_claim.pdf	Subcontractor Progress Claim #1	SYNTHETIC	SUB-001
fixtures/completion_checklist.pdf	Completion Checklist	SYNTHETIC	CLOSE-001
fixtures/test_warranty.pdf	Warranty (fixture)	SYNTHETIC	CLOSE-001
fixtures/turnover_index.pdf	Turnover Index	SYNTHETIC	CLOSE-001
fixtures/final_report.pdf	Final Report	SYNTHETIC	LC-COMPLETE-001
fixtures/completion_certificate.pdf	Certificate of Completion (fixture)	SYNTHETIC	LC-COMPLETE-001
fixtures/ai_injection_probe.pdf	Spec section with embedded instruction-like text	SYNTHETIC	AI-INJ-001
fixtures/time_entries.csv	Time entries (synthetic)	SYNTHETIC	JC-001

File	Purpose	Provenance	Tests
fixtures/production_entries.csv	Production entries	SYNTHETIC	PROD-001
fixtures/retainage_schedule.csv	Retainage schedule	SYNTHETIC	PAY-FB-, *RET-*
fixtures/punch_list.csv	Punch list	SYNTHETIC	PUNCH-001
fixtures/site_diagram.png	Synthetic site diagram	SYNTHETIC	(attachments blocked: object storage)
fixtures/as_built_demo.png	As-built demonstration attachment	SYNTHETIC	CLOSE-001
fixtures/prevailing_wage_valid.csv	Valid prevailing-wage import (positive)	SYNTHETIC	FILE-POS-001
fixtures/prevailing_wage_valid.xlsx	Valid prevailing-wage XLSX	SYNTHETIC	FILE-POS-002
fixtures/negative/empty.csv	Empty file	SYNTHETIC negative	FILE-NEG-001
fixtures/negative/image_named.xlsx	PNG bytes with .xlsx extension (wrong ext/MIME)	SYNTHETIC negative	FILE-NEG-002
fixtures/negative/corrupt.xlsx	Truncated XLSX (corrupt)	SYNTHETIC negative	FILE-NEG-003
fixtures/negative/corrupt.pdf	Truncated PDF (corrupt)	SYNTHETIC negative	(attachment uploads blocked)
fixtures/negative/missing_required_column.csv	Missing required columns	SYNTHETIC negative	FILE-NEG-004
fixtures/negative/invalid_values.csv	Invalid date/number values	SYNTHETIC negative	FILE-NEG-005
fixtures/negative/oversized_5MiB_plus.csv	Bounded oversized file (limit 5 MiB + 256 KiB)	SYNTHETIC negative	FILE-NEG-006
fixtures/negative/duplicate_of_valid.csv	Duplicate document (same bytes as valid)	SYNTHETIC negative	FILE-NEG-007
fixtures/schedule_expected_cpm.json	Independent CPM expectation	DERIVED/SYNTHETIC	SCH-004
fixtures/billing_expected.json	Independent G702 expectations (3 periods)	DERIVED/SYNTHETIC	PAY-FB-*
fixtures/source/00420_Crane_Logistics_2nd_take_off_with_changes_(2).xlsx	ORIGINAL supplied estimate (immutable, chmod 444)	SOURCE (user-supplied)	EST-*, UI-IMP-001

App-generated documents, all in evidence/docs/:

- Proposal PDFs (EST-PROP-001/002)
- G702/G703 PDFs (PAY-FB-00x-*)
- Punch and closeout HTML exports

Run commands (secrets via env vars only):

```
export SMA_QA_ADMIN_PASSWORD=...   # supplied privately; never committed
export SMA_QA_RUN_ID=SMA-QA-<UTC>
set -a; . qa/.local.env; set +a   # gitignored; see qa/README.md for variables
node qa/harness/stage1.mjs && node qa/harness/stage2.mjs && ...   # see README for full order
```

End of report.